

PraisonAI Platform has a cross-workspace IDOR + member-role privilege escalation

Report Type: Weekly · Generated: May 31, 2026 05:30 UTC · Coverage: May 29 – May 31, 2026

1	1	0	0
Total Advisories	Critical	High	Medium

Executive Summary

Summary The Platform server exposes resources under `/api/v1/workspaces/{workspace_id}/...` and protects them with a `require_workspace_member(workspace_id)` FastAPI dependency. The dependency only checks that the caller is a member of the `workspace_id` in the URL prefix. The route handlers then look up the inner resource (`agent_id`, `issue_id`, `project_id`, `label_id`, `comment_id`, `dependency_id`) by primary key alone. The resource's own `workspace_id` is never compared to the URL's `workspace_id`. A user can therefore put their own workspace in the URL prefix and any other workspace's resource ID in the path. The auth check passes, since they really are a member of the prefix workspace. The service then returns the cross-tenant resource for read, update, or delete. There is a second bug in the member-management routes (`add_member`, `update_member_role`, `remove_member`, `update_workspace`, `delete_workspace`). Each one inherits the default `min_role="member"` from `require_`

CONFIDENTIALITY NOTICE: This report is classified PRO tier and intended exclusively for the named recipient. Redistribution, resale, or disclosure to unauthorized parties is strictly prohibited. © 2026 CYBERDUDEBIVASH SENTINEL APEX. All rights reserved.

Top Threat Advisories

High-priority advisories ranked by CVSS score, exploitability, and actor attribution.

Advisory Title	Severity	CVSS	EPSS	AI Summary
PraisonAI Platform has a cross-workspace IDOR + member-role privilege es —	Critical	9.5	0.0000	## Summary The Platform server exposes resources under `/api/v1/worksp

MITRE ATT&CK;® Coverage

ATT&CK; technique density score: 0.0 · Techniques observed: 0 · Tactics covered: 0

Threat Actor Intelligence

Attribution analysis across advisories in this report period.

Threat Actor	Advisory Count	Associated CVEs / Indicators
CDB-UNATTR-CVE	1	—

Actionable Recommendations

Prioritized defensive actions based on this period's intelligence.

1. Apply patches immediately for PraisonAI Platform has a cross-workspace IDOR + member-role privilege escalation.
2. Enable enhanced monitoring for related IOCs.
3. Review SIEM rules for associated MITRE ATT&CK; techniques.

Appendix — Report Metadata & Legal

Field	Value
Report ID	intel--8a2eca7c0fab
Report Type	Weekly
Platform	CYBERDUDEBIVASH SENTINEL APEX v143.0.0 GOD-MODE
Generated At	2026-05-31T05:30:23.441035+00:00
Customer Tier	PRO
Customer Email	—
TLP	TLP:CLEAR
STIX Version	2.1
ATT&CK Version	v15

Legal & Usage Notice

This threat intelligence report is produced by CYBERDUDEBIVASH SENTINEL APEX, operated by Bivash Nath (GSTIN: 21ARKPN8270G1ZP). All intelligence is aggregated from public vulnerability databases (NVD, CVSS), threat feeds, and proprietary AI enrichment pipelines. This report is provided AS-IS for informational and defensive security purposes only. CYBERDUDEBIVASH accepts no liability for actions taken based on this intelligence. Redistribution, resale, or disclosure to unauthorized parties is strictly prohibited without written consent. For licensing inquiries contact bivash@cyberdudebivash.com.